step: 1.1

plan: ../PLAN-MASTER.md

agent: tech-lead

status: done

completed_at: 2026-11-02T16:54:00+07:00

deps: []

STEP 1.1 — Khảo sát Mã nguồn & Phân tích Kỹ thuật Toàn diện (4 mảng)

Input nhận

- Yêu cầu gốc từ User: "Phân tích hệ thống nêu ra ưu diểm , nhược điểm + đề xuất"
- Kết quả Scope Check: Mục tiêu Read-only Audit (chưa sửa code), Priority P1 (chuẩn bị Golive & Scale), phạm vi toàn diện 4 mảng (Web/Backend/DB/Auth/Perf, UI/UX/Nghiệp vụ, C# Avalonia Mobile, Infra/Docker/CI-CD/Agent).
- Danh sách module gợi ý & các điểm `UNCERTAIN` từ `_workspace/CONTEXT-HINTS.md`.

Nhiệm vụ

Đọc `code-graph/CODE-GRAPH.md` trước, sau đó kiểm chứng trực tiếp mã nguồn thực tế trên cả 4 mảng của hệ thống **KZTEK Work Management**. Áp dụng chuẩn từ vựng `codebase-design` và khung kiểm định bảo mật `security-audit-stride` (OWASP Top 10 + STRIDE) để biên soạn báo cáo phân tích chuyên sâu `docs/architecture/ARCH-AUDIT-system-2026-11-02.md` (nêu rõ Kiến trúc tổng thể bằng Mermaid, Ưu điểm cốt lõi, Nhược điểm / Rủi ro P0-P3 kèm dẫn chứng `file:line`, và Đề xuất kỹ thuật chi tiết).

Definition of Done

- [x] Đã kiểm chứng thực tế tất cả 4 nhóm điểm `UNCERTAIN` trong `_workspace/CONTEXT-HINTS.md` bằng mã nguồn thật (`file:line`), không dựa vào suy đoán.
- [x] Xuất đầy đủ báo cáo `docs/architecture/ARCH-AUDIT-system-2026-11-02.md` gồm: Sơ đồ kiến trúc Mermaid, Phân tích Ưu điểm & Nhược điểm theo từng phân hệ (Backend/DB, Bảo mật OWASP+STRIDE, Hiệu năng/Realtime, Frontend UI/UX & Nghiệp vụ, C# Avalonia Mobile & Rule R9, Infra/Docker/CI-CD & `.gemini/`), và Danh mục đề xuất cải tiến phân nhóm rõ ràng.
- [x] Chạy `python scripts/md_to_docx_kztek.py` cho file báo cáo và file step này (kiểm tra `.docx` / `.pdf` trên đĩa theo G005).
- [x] Cập nhật đầy đủ mục `Đã làm`, `Artifact`, `Handoff Payload` (3 key), `status: done` vào file step này, cập nhật 1 dòng status trong `PLAN-MASTER.md`, và commit đúng các file thuộc bước 1.1.

Đã làm

- Kiểm chứng 100% bằng chứng mã nguồn (`CONFIRMED` kèm `file:line`) cho cả 4 điểm `[UNCERTAIN-*]` từ `_workspace/CONTEXT-HINTS.md`: xác nhận runtime dùng 100% PostgreSQL 17 (`prisma/schema.prisma:7`, `src/lib/prisma.ts:30-35`, `CODE-GRAPH.md` bị lệch ghi SQL Server), xác nhận `NotificationQueue` & `boardBus` & `emailOutbox` chạy thuần in-memory RAM đơn tiến trình, kiểm toán toàn bộ 57 REST API route handlers & cơ chế Auth/RBAC/Upload/XSS, và đối chiếu toàn bộ project C# `mobile/KztekWorkManagement.Mobile/`.
- Thực hiện đánh giá thiết kế theo bộ từ vựng `codebase-design` (Deep vs Shallow modules, Leaky abstractions, Information hiding, Red flags) và kiểm định bảo mật đầy đủ theo `security-audit-stride` (OWASP Top 10 2021 + STRIDE).
- Biên soạn báo cáo kiến trúc toàn diện `docs/architecture/ARCH-AUDIT-system-2026-11-02.md` gồm sơ đồ Mermaid `flowchart TD`, phân tích Ưu điểm 4 mảng, bảng kiểm OWASP + STRIDE, danh mục Nhược điểm gắn nhãn Tech Lead (`Critical:`, bắt buộc, `Optional:`, `Nit:`), và Lộ trình nâng cấp 3 giai đoạn (`G0` Quick-wins ~9 man-days, `G1` Ngắn hạn 1–3 tháng ~22 man-days, `G2` Dài hạn 6–18 tháng ~32 man-days).
- Xuất thành công bộ tài liệu chuẩn KZTEK (`.docx` + `.pdf`) qua `scripts/md_to_docx_kztek.py` (với `$env:PYTHONIOENCODING='utf-8'`).

Artifact

- `docs/architecture/ARCH-AUDIT-system-2026-11-02.md`
- `docs/architecture/ARCH-AUDIT-system-2026-11-02.docx`
- `docs/architecture/ARCH-AUDIT-system-2026-11-02.pdf`
- `docs/plans/PLAN-system-audit-and-roadmap-2026-11-02/steps/STEP-1.1-tech-lead-system-audit.md` (+ `.docx`, `.pdf`)

Quyết định quan trọng

- **Đánh giá Security Gate = `🔴 BLOCK GOLIVE` (8/10 hạng mục OWASP Fail):** Không cho phép mở cổng Production/Internet (và cảnh báo rủi ro cao ngay cả trên LAN đông người) cho đến khi hoàn tất gói **Phase G0 (~9 man-days)** nhằm khóa lỗ hổng leo thang đặc quyền `ADMIN` không cần xác thực (`POST /api/auth/register` + `POST /api/users` / `PATCH /api/users/[userId]`), che/mã hóa secret trong `/api/system/config`, vá Stored XSS (`DOMPurify` + chặn `.html/.svg` upload + bật `httpOnly: true` hợp lý), và thêm `src/proxy.ts` tập trung.
- **Chiến lược cho C# Avalonia Mobile & `/desktop`:** Không vá chắp vá trên UI mặc định hiện tại của Mobile mà đưa vào **Phase G1** để vừa sửa các API lệch contract (`PATCH /api/tasks/[id]`, `GET /api/projects/[id]/tasks/[taskId]`, `PATCH /api/notifications/[id]`), vừa chuẩn hóa 100% sang thư viện nội bộ `KztekComponentAvalonia` theo Rule R9.
- **Chiến lược Queue & Realtime theo giai đoạn:** Ở quy mô 1 server/LAN vừa phải (G1), tận dụng ngay bảng PostgreSQL (`NotificationOutbox` + `SKIP LOCKED`) thay vì vội dựng thêm hạ tầng; chỉ bổ sung Redis Pub/Sub & S3/MinIO ở **Phase G2** khi thực sự chạy multi-replica scale-out.

Handoff Payload — bước sau đọc phần này (chỉ phần này, không cần đọc "Đã làm")

- do_not_redo: Đã kiểm chứng trực tiếp 100% source code thực tế (`file:line`) trên cả 4 mảng (57 REST API routes, Prisma 7 PostgreSQL schema, `AppShell`/`BoardView`/`MyWork`/`/desktop`/`/portal`, C# Avalonia Mobile `mobile/KztekWorkManagement.Mobile/`, `Dockerfile`/`docker-compose.yml`/`.github/workflows/deploy.yml`/`.gemini/`) và đã lập đầy đủ bảng kiểm OWASP Top 10 + STRIDE trong `docs/architecture/ARCH-AUDIT-system-2026-11-02.md` — CTO không cần quét lại mã nguồn thô.
- watch_out: (1) Working tree đang có `_workspace/` untracked — TUYỆT ĐỐI chỉ `git add` đúng các file thuộc `docs/architecture/` và `docs/plans/PLAN-system-audit-and-roadmap-2026-11-02/` (cấm `git add .` hoặc `git add -A`); (2) Khi chạy `python scripts/md_to_docx_kztek.py` trên Windows PowerShell PHẢI đặt `$env:PYTHONIOENCODING='utf-8'` để tránh lỗi `UnicodeEncodeError (cp1252)` và kiểm tra file `.pdf` trên đĩa theo G005; (3) Giữ nghiêm ngặt chế độ Read-Only với toàn bộ source code ứng dụng; (4) `code-graph/CODE-GRAPH.md` đang chứa thông tin cũ (`SQL Server` thay vì `PostgreSQL 17`), chỉ căn cứ theo dẫn chứng `CONFIRMED` trong báo cáo Audit.
- next_inputs: Đọc `docs/architecture/ARCH-AUDIT-system-2026-11-02.md` (trọng tâm Mục 2 Kiến trúc & `codebase-design`, Mục 4 Kết quả OWASP/STRIDE 🛑 `BLOCK GOLIVE` với 6 nhóm `Critical:`, Mục 5 Danh mục Nhược điểm, và Mục 6 Lộ trình nâng cấp 3 giai đoạn G0=9 man-days / G1=22 man-days / G2=32 man-days) để thẩm định chiến lược công nghệ, chốt ma trận ưu tiên đầu tư (Impact vs Effort), quyết định điều kiện Golive (LAN nội bộ có điều kiện vs Internet Production) và ban hành `docs/architecture/ADR-001-system-architecture-roadmap.md`.

Commit

- Hash: (cập nhật ngay khi tạo commit Step 1.1)
- Đã push: (kiểm tra git push)

Status icons: ☐ Todo | 🔄 In Progress | ✅ Done | 🛑 Blocked | ⏭ Skipped